

Task 1

Introduction

Cyber Kill Chain®

Know the enemy.
Break the chain.
Protect what matters.



- The term Kill chain is a military concept related to the structure of an attack. It consists of target identification, decision and order to attack the target, and finally the target destruction.



- Thanks to Lockheed Martin, a global security and aerospace company, that established the Cyber Kill Chain® framework for the cybersecurity industry in 2011 based on the military concept. The framework defines the steps used by adversaries or malicious actors in cyberspace. To succeed, an adversary needs to go through all phases of the Kill Chain.



Why is it important?

- The Cyber Kill Chain will help you understand and protect against ransomware attacks, security breaches as well as Advanced Persistent Threats (APTs).
- You can use the Cyber Kill Chain to assess your network and system security by identifying missing security controls and closing certain security gaps based on your company's infrastructure.

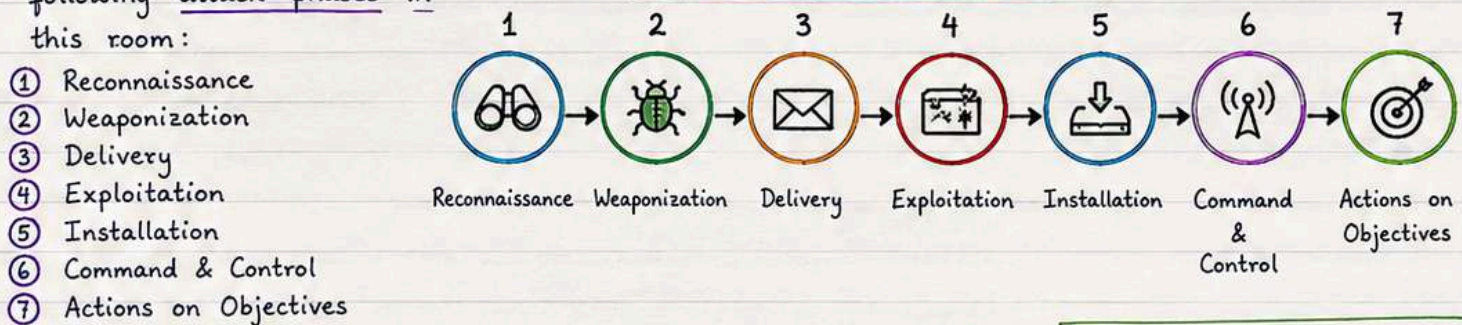
★ Helps you to:



- ✓ Understand adversaries and their techniques
- ✓ Recognize intrusion attempts
- ✓ Understand the intruder's goals and objectives
- ✓ Break the kill chain!

- ★ We will be exploring the following attack phases in this room:

The 7 Phases of the Cyber Kill Chain



Learning Objectives

- Learn about each phase of the Cyber Kill Chain Framework.
- Understand the advantages and disadvantages of the traditional Cyber Kill Chain.

Outcome

You will be ready to recognize different phases or stages of the attack carried out by an adversary and be able to break the "kill chain."

★ Understand → Detect → Defend → Respond ★

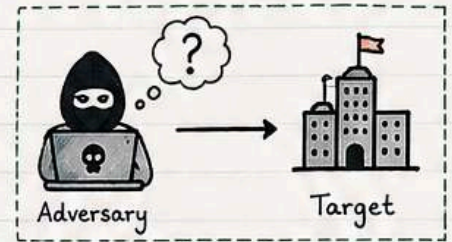
Task 2

Reconnaissance

Information is Power.
The more you know about
your target, the higher
your chances of success.

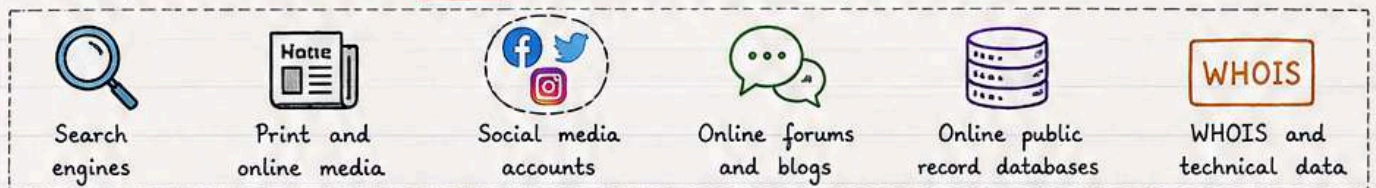


☆ Reconnaissance is the research and planning phase of an attack against a system or victim. Adversaries use this phase to gather information about their target to inform their next steps. This information can include infrastructure details, employee data, business processes, and exposed technologies. Reconnaissance is often passive and undetected.



Poor recon typically leads to sloppy attacks, while well informed adversaries can create highly targeted, believable payloads that increase their chances of success.

☆ A valuable piece of recon is **OSINT** (Open-Source Intelligence). With OSINT, adversaries gather insights about their target through publicly available information. Some public sources where OSINT data can be collected from include:



Find out more about OSINT from this Varonis article, "What is OSINT?"

Reconnaissance Types

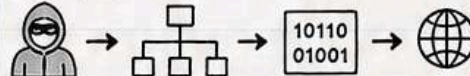
① Passive Recon

This involves having no direct interaction with the target. This may include WHOIS lookups, social media scraping, or reviewing breach data.



② Active Recon

This involves direct contact with the target with activities such as social engineering, port scanning, banner grabbing, or probing for open services.



Key Takeaway

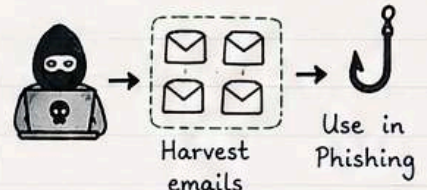
Recon is the first step. Without it, the rest of the attack chain can't move forward!

☆ Let's look at it from the attacker's perspective, who initially doesn't know what company he wants to attack. A malicious attacker who names himself "**Megatron**" decides to conduct a very sophisticated attack that he has been planning out for years; he has been studying and researching different tools and techniques that could help him get to the last phase of the Cyber Kill Chain. But first, he needs to start from the Reconnaissance phase.

☆ In order to operate in this phase, the attacker would need to conduct **OSINT**. Let's have a look at **Email harvesting**.



Email harvesting is the process of obtaining email addresses from public, paid, or free services. An attacker can use email-address harvesting for a **phishing** attack (a type of social-engineering attack used to steal sensitive data, including login credentials and credit card numbers).



☆ The attacker will have a big arsenal of tools available for reconnaissance purposes. Here are some of them:

- **theHarvester** : Other than gathering emails, this tool is also capable of gathering names, subdomains, IPs, and URLs using multiple public data sources.
- **Hunter.io** : This is an email hunting tool that will let you obtain contact information associated with the domain.
- **OSINT Framework** : OSINT Framework provides the collection of OSINT tools based on various categories.

Good Recon =
Better Attack
Success!



Task 3

Weaponization

Good weapons make attacks effective.
Great weapons make them invisible.



- ★ After a successful reconnaissance stage, "**Megatron**" would work on turning the raw information into actionable attack tools through crafting malware and exploits into a payload.



- ★ Most attackers usually use automated tools to generate the malware or refer to the DarkWeb to purchase the malware.
More sophisticated actors or nation-sponsored APT (Advanced Persistent Threat Groups) would write their custom malware to make the malware sample unique and evade detection on the target.



Before we proceed, let's define some key terminology.

- **Malware :**  Malware is a program or software that is designed to damage, disrupt, or gain unauthorized access to a computer.
- **Exploits :**  Exploits are programs or code that take advantage of the vulnerability or flaw in the application or system.
- **Payload :**  A payload is a malicious code that the attacker runs on the system.

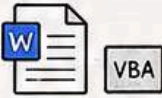
Key Takeaway

Weaponization =
Turning information
into ammunition.



Continuing with our scenario, "**Megatron**" chooses to buy an already written payload from someone else in the DarkWeb, so that he can spend more time on the other phases.

- ★ In the Weaponization phase, the attacker can adopt the following tactics:

① 	Create an infected Microsoft Office document containing a malicious <u>macros</u> or <u>VBA</u> (Visual Basic for Applications) scripts.
② 	Create a malicious payload or a very sophisticated worm, implant it on <u>USB drives</u> , and then distribute them in public.
③ 	Set up <u>Command and Control (C2)</u> infrastructure for executing the commands on the victim's machine or deliver more payloads.
④ 	Infect the victim's host with a <u>backdoor</u> , which would provide a way to access the computer system, and bypass the security mechanisms.
⑤ 	Tailoring <u>phishing</u> templates or <u>OAuth-consent</u> apps to look legitimate and dupe the victim.

Remember

Weaponization is where the attacker prepares the tools that will be used to deliver, exploit, and control.



Recon gave the attacker information.
Weaponization turns that information into a weapon.

Reconnaissance
(Information)

Weaponization
(Weapon)

Ready for
Delivery!

Task 4

Delivery

Goal: Get the payload onto the target environment.



Delivery is when **Megatron** decides to choose the method for transmitting the payload or the malware onto the target environment.

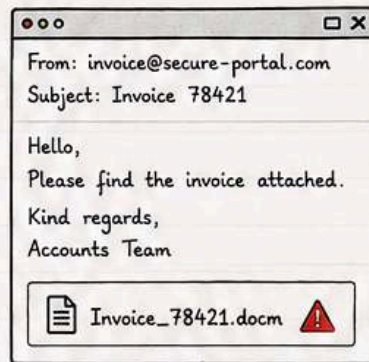
There are plenty of options to choose from:

① Phishing Email

- After conducting the reconnaissance and determining the targets for the attack, the malicious actor could craft a malicious email that would target either a specific person (spear phishing attack) or multiple people in the company.
- The email would contain a **malicious link** or **email attachment** that would result into a compromise.



Malicious Email



System Compromised!

Malicious link or attachment leads to compromise

② USB Drops

- USB drops offer the attacker a physical delivery medium into public places like coffee shops, car parks, or on the street.
- An attacker might decide to conduct a sophisticated USB Drop Attack by printing the company's logo on the USB drives and mailing them to the company while pretending to be a customer sending the USB devices as a gift.



USB drive with company logo



Mailed to the company as a "gift"



Malware executes when USB is used

③ Watering Hole Attacks

- Watering hole attacks are targeted and designed to aim at a specific group of people by compromising the website they are usually visiting, redirecting them to a malicious website of the attacker's choice or creation.
- Victims would unintentionally download malware or a malicious application to their computer, resulting in a drive-by download.
- An example can be a malicious pop-up asking to download a **fake Browser extension**.

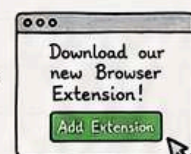
How it works:



Victim visits legitimate website



Website is compromised



Redirected or served malicious content



Malware / malicious extension installed (drive-by download)



System Compromised!

Example:

Malicious pop-up asking to download a fake Browser extension.



Delivery is all about getting the **weapon (payload)** in front of the target. The more convincing and convenient the delivery method, the higher the chance of success for **Megatron**.



Task 5

Exploitation

This is where the attacker's code executes on the target, taking advantage of a known vulnerability.



Exploitation is the moment the attacker's code executes on the target, taking advantage of a known vulnerability.

In this phase, **Megatron** can opt to utilise a number of key techniques to gain access:

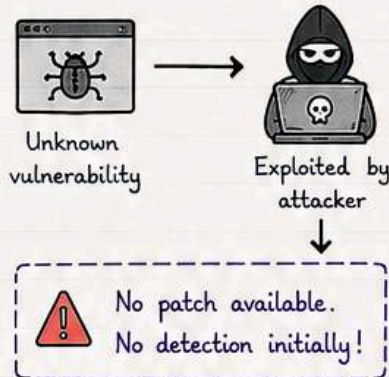
① Malicious Macro Execution

- This may have been delivered through a phishing email, that would execute **ransomware** when the victim opens it.



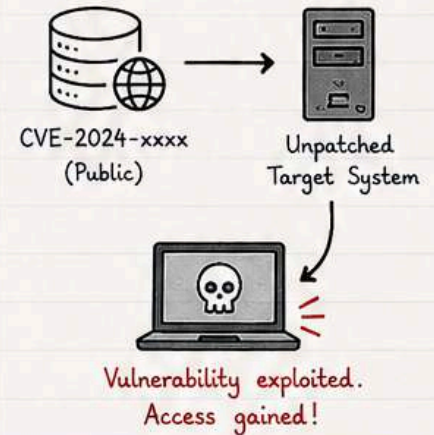
② Zero-day Exploits

- These leverages on unknown and unpatched flaws in a system. These exploits leave no opportunity for detection at the beginning.

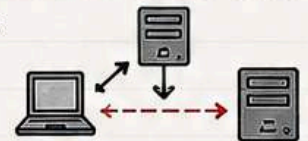


③ Known CVEs

- The attacker can choose to exploit unpatched public vulnerabilities found on the target environment.



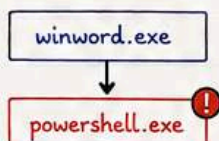
After gaining access to the system, the malicious actor could exploit software, system, or server-based vulnerabilities to escalate the privileges or move laterally through the network.



Signs of exploitation to look out for include:

① Unexpected Process Spawns

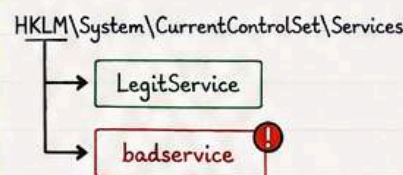
- New or unusual processes running on the system.



Unexpected child process spawned!

② Registry Changes or New Services Created

- Attackers may modify registry keys or create new services for persistence.



New suspicious service created!

③ Suspicious Command-line Arguments

- Look for unusual or encoded commands in system logs.

Process: powershell.exe
Command Line:
powershell.exe -nop -w hidden -enc SQBFAFgA...

Encoded or suspicious command detected!



Exploitation turns an opportunity into foothold.
Detect early, respond fast, stop **Megatron**!



Task 6

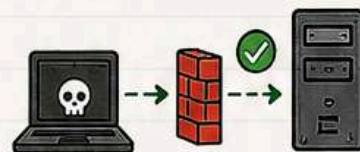
Installation

Persistence is the key.
Stay hidden. Stay connected.
Stay in control.



As you have learned from the Weaponization phase, the **backdoor** lets an attacker bypass security measures and hide the access. A backdoor is also known as an **access point**.

Once the attacker gets access to the system, he would want to reconnect back to the system if he loses the connection to it or if he got detected and got the initial access removed. Or if the system is later patched, they will no longer have access to it. That is when the attacker needs to install a **persistent backdoor**. A persistent backdoor will let the attacker access the system he compromised in the past.



Reconnect anytime,
from anywhere.



You can check out the **Windows Persistence Room** to learn how an attacker can achieve persistence on Windows.

The **persistence** can be achieved through:

① Installing a Web Shell on the Webserver



- A web shell is a malicious script written in web development programming languages such as ASP, PHP, or JSP used by an attacker to maintain access to the compromised system.

- Because of the web shell simplicity and file formatting (.php, .asp, .aspx, .jsp, etc.) can be difficult to detect and might be classified as benign.

Check out **Microsoft's** article on various web shell attacks.

② Installing a Backdoor on the Victim's Machine



- The attacker can use **Meterpreter** to install a backdoor on the victim's machine.
- Meterpreter is a **Metasploit Framework** payload that gives an interactive shell from which an attacker can interact with the victim's machine remotely and execute the malicious code.



Meterpreter
Payload



Gains interactive control of the victim's machine.

③ Creating or Modifying Windows Services



- Technique ID: **T1543.003** on MITRE ATT&CK
- Attacker can create or modify Windows services to execute malicious scripts or payloads regularly as a part of the persistence.
- Tools: **ssc.exe** (sc.exe) and **Reg**
 - sc.exe lets you Create, Start, Stop, Query, or Delete any Windows Service.
 - Reg can be used to modify service configurations.
- The attacker can also masquerade the malicious payload by using a service name that is known to be related to the OS or legitimate software.

Create / Modify
Service

Malicious
Payload

Runs at
Startups

④ Adding Entry to Run Keys or Startup Folder



- Add the entry to the "run keys" in the Registry or place the payload in the Startup Folder.
- The payload will execute each time the user logs in.
- According to MITRE ATT&CK (**T1547.001**), there is a startup folder location for individual user accounts and a system-wide startup folder that will be checked no matter what user account logs in.

Per-User Startup Folder



%APPDATA%\
Microsoft
Windows\Start Menu\Programs\Startup

System-Wide Startup Folder



%PROGRAMDATA%\
Microsoft\Windows\Start Menu
Programs\Startup

Read more about the Registry Run Keys /
Startup Folder persistence on MITRE ATT&CK.



Timestomping (T1070.006) can also be used in this phase.

- It helps the attacker avoid detection by the forensic investigator.
- Makes the malware appear as a part of a legitimate program.
- Lets an attacker modify the file's timestamps:



Modified
(M)



Accessed
(A)



Created
(C)



Changed
(CT)

Original File
(Timestamps)



Modified File
(Legitimate-looking)



Blends in. Stays hidden.

Key Goal:

Maintain access
silently and
stay **persistent**!

Task 7

Command & Control

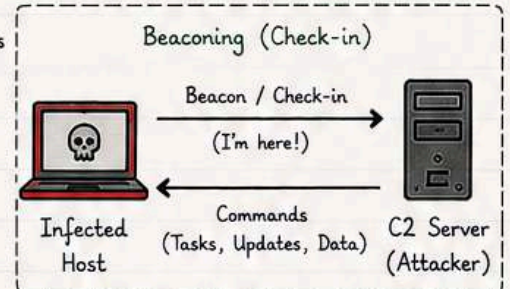
C2 = Remote control.

C&C Beaconsing =
"I'm here, ready for
commands!"

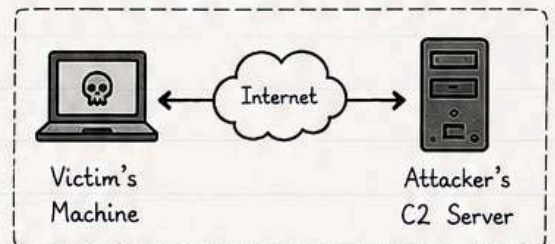


After getting **persistence** and executing the malware on the victim's machine, **Megatron** opens up the **C2** (Command and Control) channel through the malware to remotely control and manipulate the victim.

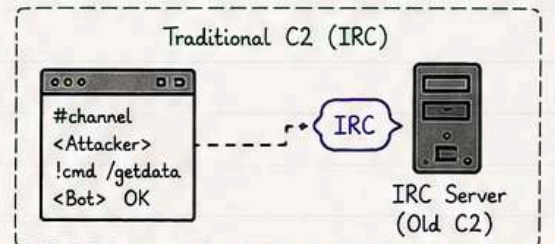
- ☆ This term is also known as **C&C** or C2 Beaconsing as a type of malicious communication between a C&C server and malware on the infected host. The infected host will consistently communicate with the C2 server; that is also where the beaconsing term came from.



- ☆ The compromised endpoint would communicate with an external server set up by an attacker to establish a command & control channel. After establishing the connection, the attacker has full control of the victim's machine.



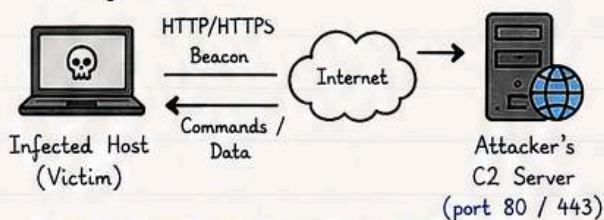
- ☆ Until recently, IRC (Internet Relay Chat) was the traditional C2 channel used by attackers. This is no longer the case, as modern security solutions can easily detect malicious IRC traffic.



The most common C2 channels used by adversaries include:

① HTTP / HTTPS (Port 80 / 443)

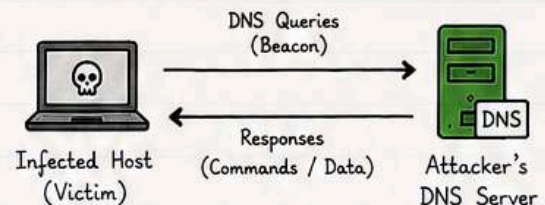
- The infected host beacons to the attacker's server using HTTP or HTTPS.
- This blends malicious traffic with legitimate traffic and can help the attacker evade firewalls and security tools.



Looks like normal web traffic!
Harder to block and detect.

② DNS (Domain Name Server)

- The infected machine makes constant DNS requests to the DNS server controlled by the attacker.
- This type of C2 communication is also known as DNS Tunneling.



Hides inside normal DNS traffic.
Harder to notice!



Important to note:

- An adversary or another compromised host can be the owner of the C2 infrastructure.



Attacker

C2 Infrastructure
(Could be owned by
attacker or another
compromised host)



Infected Host

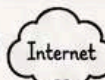
Task 8

Actions on Objectives (Exfiltration)

The final goal:
Achieve the objectives
and complete the mission.



After going through six phases of the attack, **Megatron** can finally achieve his goals, which means taking action on the original objectives. With hands-on keyboard access, the attacker can achieve the following:

① <u>Collect the credentials</u>	The attacker dumps or steals usernames, passwords, API keys, tokens, and other sensitive authentication data.	 → user : admin pass : ***** token : abcd1234 
② <u>Perform privilege escalation</u>	The attacker gains elevated access, such as domain administrator permissions, by exploiting misconfigurations or vulnerabilities.	 →  →  User Domain Administrator
③ <u>Internal reconnaissance</u>	The attacker explores the internal network and systems to identify hosts, services, users, and potential vulnerabilities.	 →  → 
④ <u>Lateral movement</u>	The attacker moves from the compromised host to other systems within the environment to expand their access.	 →  →  →  Compromised Host Other Internal Systems
⑤ <u>Collect and exfiltrate sensitive data</u>	The attacker gathers valuable data (documents, databases, source code, emails, etc.) and exfiltrates it to an external location.	 →  →  → 
⑥ <u>Delete backups and shadow copies</u>	The attacker deletes backups and shadow copies to prevent recovery and make restoration difficult.	 →  →  Backups Deleted Shadow Copies Deleted
 Shadow Copy is a Microsoft technology that can create backup copies, snapshots of computer files, or volumes.		
⑦ <u>Overwrite or corrupt data</u>	The attacker destroys, modifies, or corrupts data to disrupt business operations and cause damage.	 →  →  Original Data Corrupted Data Data Lost



Mission Accomplished!

The attacker has achieved the objectives:

✓ Access gained ✓ Data stolen ✓ Damage done

Without strong detection and response, the organization may not even know it happened.



Understand every phase. Detect early. Break the kill chain!

